TEAM MANGO / NETWORK + GO

LOGION SECURITY PROJECT

모의해킹 및 침해대응 최종 결과 보고서

RED 공격 수행 · BLUE Wazuh 관제 · 개선 후 재시험



MANGO / 망고

팀 프로젝트 수행 결과

CASE 01

배송지 변경 BOLA

CASE 02

물류문서 업로드

CASE 03

외주 계정 접근

GNS3 논리 토폴로지 + RED 실행 증빙 + BLUE Wazuh 이벤트

실습 증빙: 2026년 11월 5~6일 | 프로젝트: LOGION | 팀: 망고

프로젝트 목표와 핵심 성과

공격 재현부터 탐지, 대응, 재시험까지 하나의 흐름으로 검증

01

타인 주문 배송지 변경 이력

02

비허용 PHP 업로드·실행

03

외주 계정 잠금·재접속 거부

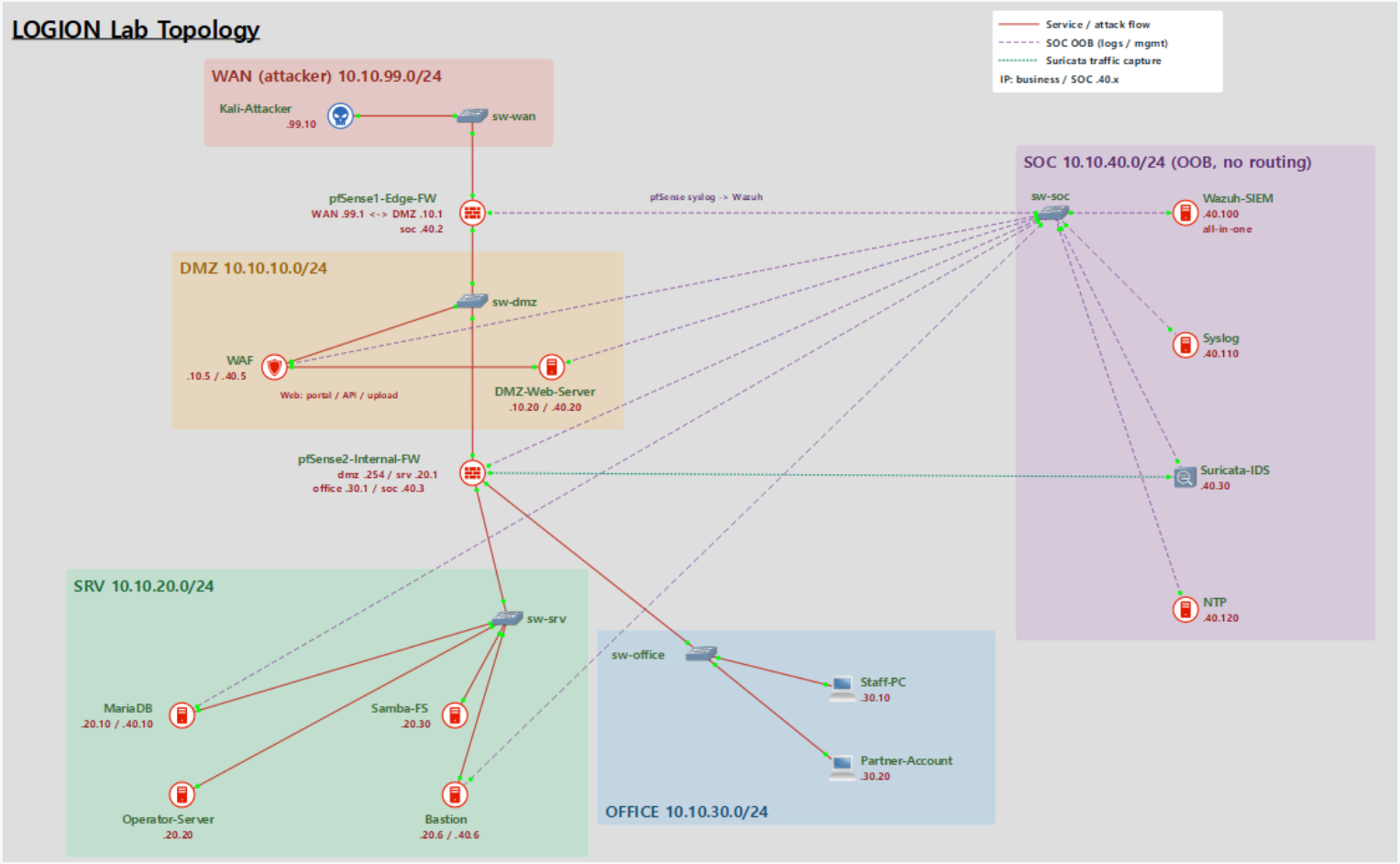
프로젝트 개요

가상의 물류·서비스 운영 환경을 구축하고, 실습용 계정과 데이터를 이용해 웹 권한, 파일 업로드 및 외주 계정 관리 시나리오를 검증했다. RED는 공격을 재현하고, BLUE는 Wazuh와 WAF 감사 이벤트를 분석했다.

검증 항목	RED팀 주요 결과	BLUE팀 주요 결과
CASE 01 · BOLA	다른 소유자 주문의 배송지 변경 이력 확인 후 소유권 검증 적용·거부 기록 확보	/api/update_shipping.php 요청의 WAF 경고 기록 확인
CASE 02 · Upload	PHP 마커 업로드 및 출력 확인, 조치 후 404와 DB REJECTED 확인	WAF 고위험 경고 100304(Level 10) 확인
CASE 03 · 외주계정	partner01 계정 상태 변경 및 Bastion SSH 재접속 거부 확인	Bastion 감사 이벤트의 Wazuh 수집 확인

LOGION 전체 논리 토폴로지

GNS3에서 표현한 WAN / DMZ / SRV / OFFICE / SOC 네트워크 구성



서비스·공격 경로는 빨간 실선, SOC 로그 전송은 보라색 점선으로 표시한 전체 논리 설계도. 실제 검증에서 주요 관제 대상은 WAF, WebAPI, MariaDB, Bastion이며 Wazuh가 관련 경고·감사 이벤트를 수집한다.

RED · BLUE 역할과 실습 절차

CASE마다 동일한 검증 순서를 적용해 전후 결과를 비교

RED TEAM | 공격 및 결과 확인

Kali와 테스트 서버에서 정상 요청, 취약 요청, DB·파일·계정 상태를 확인한다. 각 공격의 실행 시각과 응답, 변경 결과를 캡처하며 보안 조치 후 동일한 조건으로 재시험한다.

BLUE TEAM | 탐지 및 증빙

Wazuh Endpoints에서 Agent 상태를 확인하고, Threat Hunting에서 WAF·WebAPI·Bastion 이벤트를 검색한다. 규칙 ID, 이벤트 시간, 출발지, 요청 경로를 기록하고 RED 결과와 연결한다.

01 사전점검

토폴로지·Agent·라우팅·초기 데이터 확인

→

02 공격 재현

정상 요청과 취약 요청의 응답·실제 결과 촬영

→

03 BLUE 탐지

공격 시각에 대응하는 Wazuh 이벤트 상세 분석

→

04 조치 및 재시험

수정·계정 잠금 후 동일 요청의 결과를 비교

캡처 읽는 방법

각 CASE의 캡처는 실제 실행 화면·이벤트 목록·상세 기록·재시험 결과 순서로 구성했다. WAF 규칙 일치 결과와 애플리케이션의 데이터 변경·차단 결과는 각각 해당 증거가 보여 주는 범위로 서술했다.

사전점검 · 서버 경로와 Agent 연결

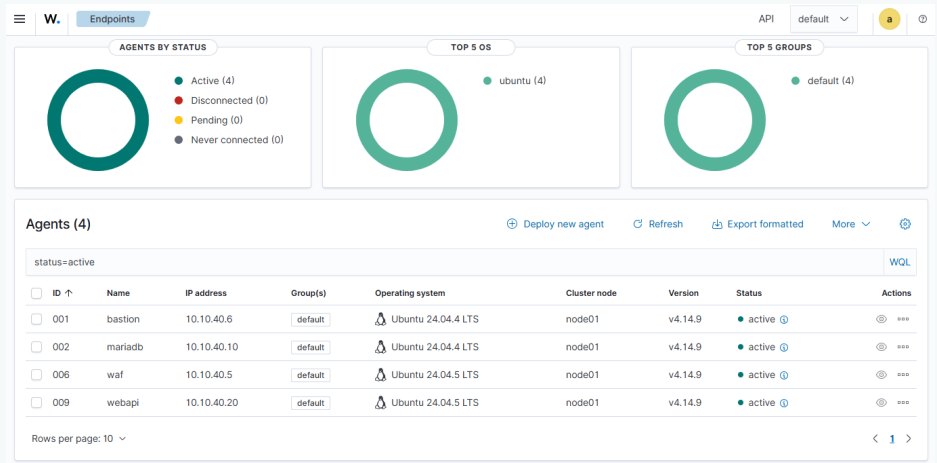
공격 전 WebAPI 연결·Wazuh 수집 상태를 확인

RED | WebAPI 네트워크 정보

```
logion@LOGION:~$ ip -br a
lo               UNKNOWN        127.0.0.1/8 ::1/128
enp0s3           UP             10.10.10.20/24 fe80::a00:27ff:fe50:6ec4/64
enp0s8           UP             10.10.40.20/24 fe80::a00:27ff:fe28:7ff9/64
enp0s9           DOWN
logion@LOGION:~$ ip route get 10.10.20.10
10.10.20.10 via 10.10.10.254 dev enp0s3 src 10.10.10.20 uid 1000
    cache
```

DMZ 10.10.10.20 · SOC 10.10.40.20 / 목적지 라우트

BLUE | Wazuh Endpoints



WAF · WebAPI · MariaDB · Bastion 4개 Agent Active

사전 준비 및 경로 확인

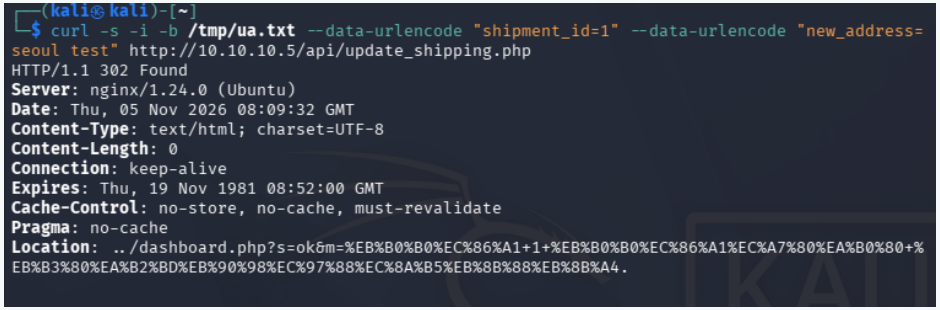
WebAPI: DMZ 10.10.10.20 · SOC 10.10.40.20 / 내부 서버망 경유: pfSense Internal(10.10.10.254)

CASE 01 서비스 경로 Kali(10.10.99.10) → Edge → WAF(10.10.10.5) → WebAPI(10.10.10.20)
→ pfSense Internal → MariaDB(10.10.20.10:3306) | Wazuh Agent 4대 Active

CASE 01 · 배송지 바꿔치기 공격

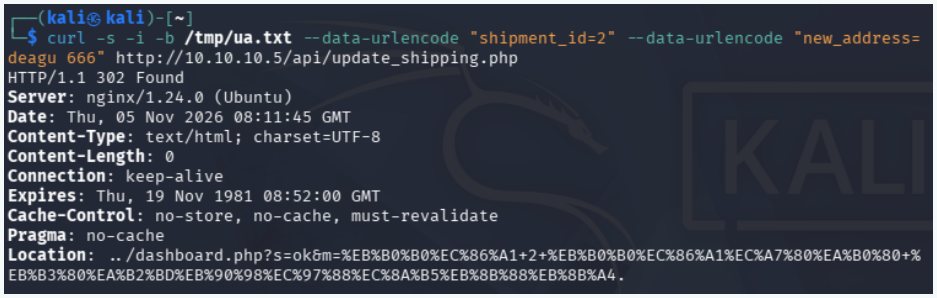
본인 소유 주문의 정상 요청과 타인 주문으로 변경한 요청을 비교

RED | 정상 배송지 요청



테스트 계정의 본인 주문 변경 요청과 HTTP 응답

RED | BOLA 요청



동일 인증 컨텍스트에서 shipment_id=2로 변경한 요청

실습 과정

정상 배송지 변경 흐름을 확인한 뒤, 다른 소유자의 주문번호를 이용한 업데이트 요청을 보냈다. HTTP 응답 코드는 302로 표시되며 변경 여부는 다음 DB 이력으로 검증했다.

CASE 01 · DB 변경 이력 검증

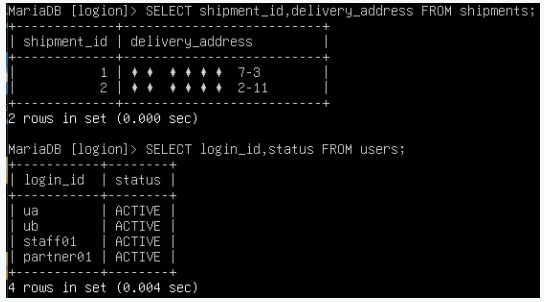
요청 행위자와 실제 주문 소유자가 다른 이력 확인

RED | shipment_address_history 조회

shipment_id	actor_user_id	owner	new_address
2	1	2	deagu 666

shipment_id=2 · actor_user_id=1 · owner=2 · new_address=daegu 666

RED | 초기 더미 데이터



```
MariaDB [logion]> SELECT shipment_id,delivery_address FROM shipments;
+-------------+------------------------+
| shipment_id | delivery_address       |
+-------------+------------------------+
|           1 | ♦♦ ♦♦♦♦ 7-3           |
|           2 | ♦♦ ♦♦♦♦ 2-11          |
+-------------+------------------------+
2 rows in set (0.000 sec)

MariaDB [logion]> SELECT login_id,status FROM users;
+-----------+--------+
| login_id  | status |
+-----------+--------+
| ua        | ACTIVE |
| ub        | ACTIVE |
| staff01   | ACTIVE |
| partner01 | ACTIVE |
+-----------+--------+
4 rows in set (0.004 sec)
```

테스트용 고객과 주문 데이터의 기준 상태

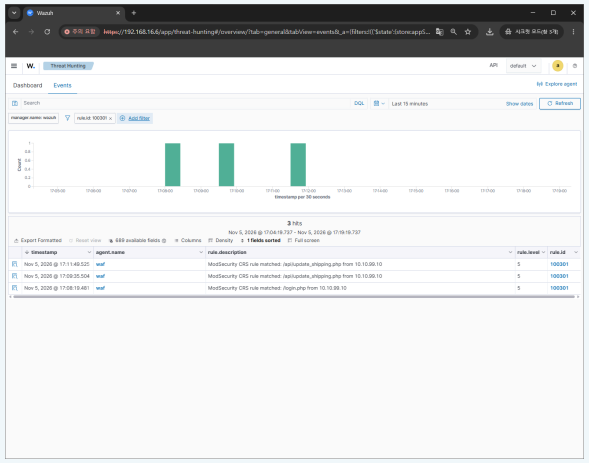
재현 결과

DB 변경 이력에서 요청 행위자 ID와 주문 소유자 ID가 다르게 나타나, 실습 환경의 소유권 검증 문제를 확인했다. 이후 서버 측 권한 검증을 적용하고 같은 대상 주문으로 재시험했다.

CASE 01 · WAF 탐지 증빙 정밀 분석

경고 목록과 핵심 필드를 확대해 BOLA 권한 검증 근거와 구분

BLUE | WAF 요청 경고 목록



3 hits

Nov 5, 2026 @ 17:04:19.737 - Nov 5, 2026 @ 17:19:19.737

Export Formatted | Reset view | 689 available fields | Columns | Density | 1 fields sorted | Full screen

timestamp	agent.name	rule.description	rule.level	rule.id
Nov 5, 2026 @ 17:11:49.525	waf	ModSecurity CRS rule matched: /api/update_shipping.php from 10.10.99.10	5	100301
Nov 5, 2026 @ 17:09:35.504	waf	ModSecurity CRS rule matched: /api/update_shipping.php from 10.10.99.10	5	100301
Nov 5, 2026 @ 17:08:19.481	waf	ModSecurity CRS rule matched: /login.php from 10.10.99.10	5	100301

/api/update_shipping.php · Kali 10.10.99.10

BLUE | 상세 이벤트 핵심 필드

출발지 IP · 수집 Agent

agent.id	006
agent.ip	10.10.40.5
agent.name	waf
data.transaction.client_ip	10.10.99.10
data.transaction.client_port	48050
data.transaction.host_ip	10.10.10.5
data.transaction.host_port	80

규칙 정보 · 이벤트 시각

manager.name	wazuh
rule.description	ModSecurity CRS rule matched: /api/update_shipping.php from 10.10.99.10
rule.firedtimes	3
rule.groups	web, modsecurity, waf
rule.id	100301
rule.level	5
rule.mail	false
timestamp	Nov 5, 2026 @ 17:11:49.525

Wazuh 100301 · Level 5 | ModSecurity CRS 920350

CASE 01 탐지 해석

WAF의 100301(Level 5)은 배송지 변경 API에 대한 ModSecurity 규칙 매칭이다. 실제 규칙 920350은 숫자 IP를 사용한 Host 헤더에 반응한 것으로, 이 이벤트만으로 BOLA를 판정하지 않는다.

BOLA(객체별 권한 검증 문제)는 shipment_address_history의 행위자/소유자 불일치로 확인하고, 조치 후 api_audit_logs의 403 / DENIED 기록과 함께 대응 효과를 검증했다.

CASE 01 · 보안 조치 후 재시험

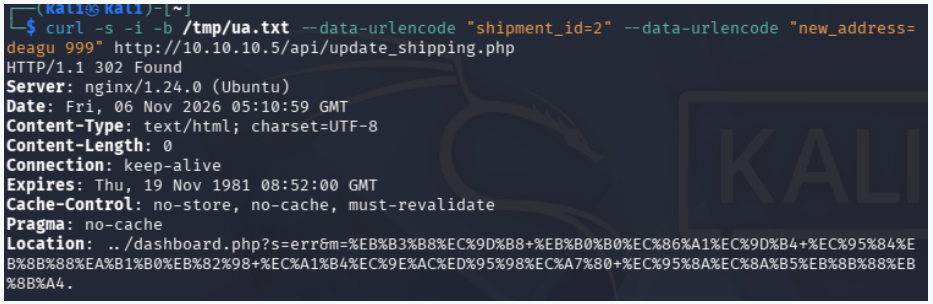
서버 측 권한 검증 적용 후 동일 주문을 재요청

서버 | 업데이트 처리 코드 반영

```
logion@LOGION:~$ sudo cp -f ~/logion-webapi/security/fixed/update_shipping.php /var/www/html/api/update_shipping.php
```

fixed/update_shipping.php 적용 명령 기록

RED | 재요청



```
┌──(kali㉿kali)-[~]
└─$ curl -s -i -b /tmp/ua.txt --data-urlencode "shipment_id=2" --data-urlencode "new_address=
deagu 999" http://10.10.10.5/api/update_shipping.php
HTTP/1.1 302 Found
Server: nginx/1.24.0 (Ubuntu)
Date: Fri, 06 Nov 2026 05:10:59 GMT
Content-Type: text/html; charset=UTF-8
Content-Length: 0
Connection: keep-alive
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Location: ../dashboard.php?s=err6m=%EB%B3%B8%EC%9D%B8+%EB%B0%B0%EC%86%A1%EC%9D%B4+%EC%95%84%E
B%8B%88%EA%B1%B0%EB%82%98+%EC%A1%B4%EC%9E%AC%ED%95%98%EC%A7%80+%EC%95%8A%EC%8A%B5%EB%8B%88%EB
%8B%A4.
```

같은 shipment_id=2 대상 재시험 응답

RED | 최종 DB 확인



```
logion@mariadb:~$ sudo mysql -e "SELECT shipment_id,delivery_address,updated_at FROM logion.shipments WHERE shipment_id=2;"
[sudo] password for logion:
+-------------+------------------+---------------------+
| shipment_id | delivery_address | updated_at          |
+-------------+------------------+---------------------+
|           2 | deagu 666        | 2026-11-05 08:11:44 |
+-------------+------------------+---------------------+
logion@mariadb:~$ sudo mysql -e "SELECT actor_user_id,target_id,http_status,result FROM logion.api_audit_logs WHERE result='DENIED' ORD
;"
+---------------+-----------+-------------+--------+
| actor_user_id | target_id | http_status | result |
+---------------+-----------+-------------+--------+
|             1 |         2 |         403 | DENIED |
+---------------+-----------+-------------+--------+
```

배송지 값 유지, api_audit_logs에서 403 / DENIED 기록

CASE 02 · 물류문서 파일 업로드

허용 파일과 비허용 PHP 마커 파일의 처리 결과를 비교

RED | 정상 업로드

```
┌──(kali㉿kali)-[~]
└─$ echo 'normal document' > /tmp/normal.txt

┌──(kali㉿kali)-[~]
└─$ echo '<?php echo "LOGION-MARKER"; ?>' > /tmp/marker.php

┌──(kali㉿kali)-[~]
└─$ curl -s -c /tmp/p.txt -d [redacted]http://10.10.10.5/login
.php

┌──(kali㉿kali)-[~]
└─$ curl -s -i -b /tmp/p.txt -F "doc=@/tmp/normal.txt" http://10.10.10.5/admin/upload.php
HTTP/1.1 302 Found
Server: nginx/1.24.0 (Ubuntu)
Date: Fri, 06 Nov 2026 05:27:00 GMT
Content-Type: text/html; charset=UTF-8
Content-Length: 0
Connection: keep-alive
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Location: index.php?s=ok&m=%EC%97%85%EB%A1%9C%EB%93%9C+%EC%99%84%EB%A3%8C%3A+%2Fuploads%2Fnor
mal.txt
```

정상 테스트 파일 업로드 및 HTTP 응답

RED | 비허용 파일 시험

```
┌──(kali㉿kali)-[~]
└─$ curl -s -i -b /tmp/p.txt -F "doc=@/tmp/marker.php" http://10.10.10.5/admin/upload.php
HTTP/1.1 302 Found
Server: nginx/1.24.0 (Ubuntu)
Date: Fri, 06 Nov 2026 05:28:24 GMT
Content-Type: text/html; charset=UTF-8
Content-Length: 0
Connection: keep-alive
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Location: index.php?s=ok&m=%EC%97%85%EB%A1%9C%EB%93%9C+%EC%99%84%EB%A3%8C%3A+%2Fuploads%2Fmar
ker.php


┌──(kali㉿kali)-[~]
└─$ curl -s http://10.10.10.5/uploads/marker.php
LOGION-MARKER
```

marker.php 업로드 뒤 /uploads/marker.php에서 LOGION-MARKER 출력

공격 재현 결과

비허용 PHP 마커 파일이 서버에 저장되어 요청 시 마커 문자열을 반환했다. 이를 통해 업로드 형식 검증과 실행 경로 분리의 필요성을 실습으로 확인했다.

CASE 02 · 업로드 결과의 서버·DB 검증

파일 시스템과 uploaded_documents 기록을 함께 확인

RED | WebAPI 업로드 폴더

```
logion@LOGION:~$ ls -l /var/www/html/uploads/
total 12
-rw-r--r-- 1 www-data www-data 31 Nov  6 05:28 marker.php
-rw-r--r-- 1 www-data www-data 16 Nov  6 05:27 normal.txt
-rwxrwxrwx 1 www-data www-data 79 Nov  2 05:30 README.txt
```

/var/www/html/uploads/에 테스트 파일과 marker.php 존재

RED | MariaDB 업로드 기록

```
+-------------+-------------------+--------------------------+-------------------+
| document_id | original_filename | mime_type                | validation_status |
+-------------+-------------------+--------------------------+-------------------+
|           2 | marker.php        | application/octet-stream | ACCEPTED          |
|           1 | normal.txt        | text/plain               | ACCEPTED          |
+-------------+-------------------+--------------------------+-------------------+
```

marker.php 등록과 ACCEPTED 상태 확인

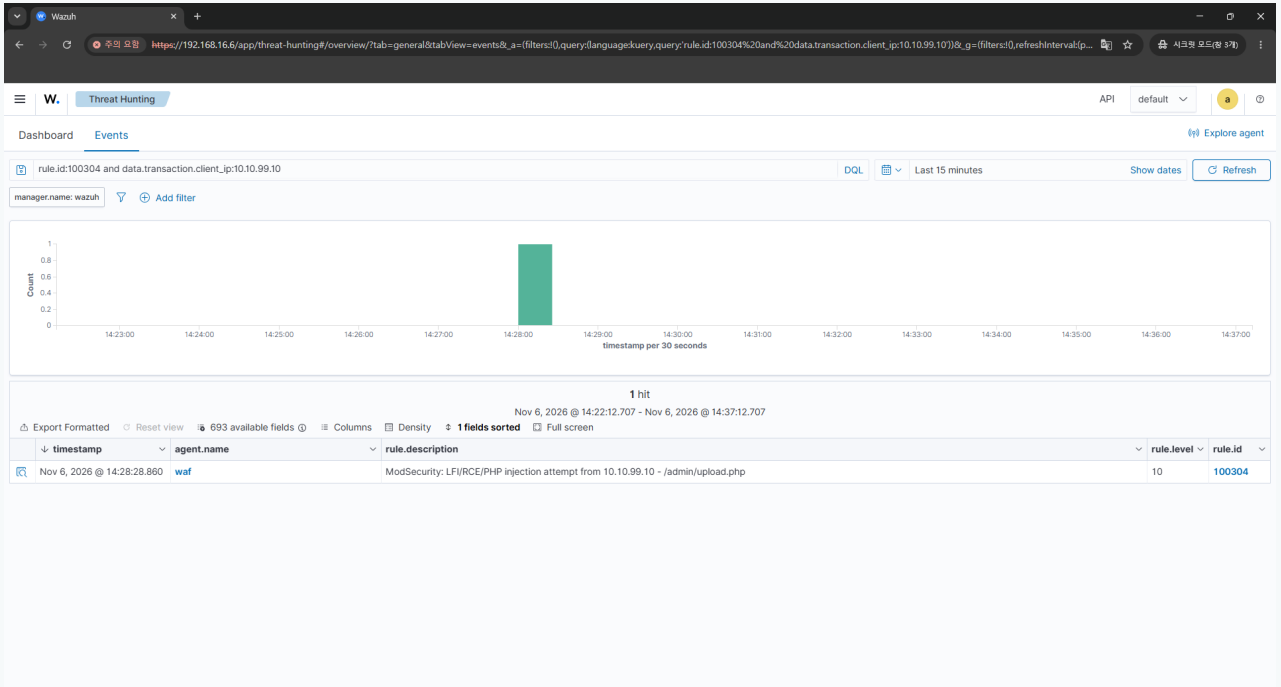
검증 결과

파일의 저장 사실과 업로드 관리 테이블의 ACCEPTED 결과가 일치하여, 취약 상태의 업로드 처리 흐름을 보여 준다.

CASE 02 · WAF 고위험 경고

Wazuh Threat Hunting에서 100304 / Level 10 탐지

BLUE | 업로드 공격 관련 경고



2026-11-06 14:28:28 · 10.10.99.10 → /admin/upload.php · Rule 100304 · Level 10

탐지 분석

WAF의 ModSecurity 규칙은 업로드 경로에 대한 LFI/RCE/PHP Injection 계열 시도를 Level 10 이벤트로 기록했다. RED팀이 캡처한 업로드 파일과 서버 응답은 별도 실행 결과로 연계했다.

CASE 02 · 업로드 보안 조치와 재시험

검증 정책 반영 후 같은 파일의 접근 결과를 재확인

서버 | 업로드 정책 반영

```
logion@LOGION:~$ ls -l /var/www/html/uploads/
total 12
-rw-r--r-- 1 www-data www-data 31 Nov  6 05:28 marker.php
-rw-r--r-- 1 www-data www-data 16 Nov  6 05:27 normal.txt
-rwxrwxrwx 1 www-data www-data 79 Nov  2 05:30 README.txt
logion@LOGION:~$ sudo cp -f ~/logion-webapi/security/fixed/upload.php /var/www/html/admin/upload.php
[sudo] password for logion:
logion@LOGION:~$ sudo mkdir -p /var/lib/logion-uploads && sudo chown www-data:www-data /var/lib/logion-uploads
logion@LOGION:~$ sudo rm -f /var/www/html/uploads/marker.php
logion@LOGION:~$ ls -l /var/www/html/uploads/
total 8
-rw-r--r-- 1 www-data www-data 16 Nov  6 05:27 normal.txt
-rwxrwxrwx 1 www-data www-data 79 Nov  2 05:30 README.txt
```

upload.php 변경, 저장 경로 정리 및 테스트 마커 제거

RED | 비허용 파일 재시험

```
┌──(kali㉿kali)-[~]
└─$ curl -s -i -b /tmp/p.txt -F "doc=@/tmp/marker.php" http://10.10.10.5/admin/upload.php
HTTP/1.1 302 Found
Server: nginx/1.24.0 (Ubuntu)
Date: Fri, 06 Nov 2026 05:42:09 GMT
Content-Type: text/html; charset=UTF-8
Content-Length: 0
Connection: keep-alive
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Location: index.php?s=err6m=%ED%97%88%EC%9A%A9%EB%90%98%EC%A7%80+%EC%95%8A%EC%9D%80+%ED%8C%8C
%EC%9D%BC%28%ED%98%95%EC%8B%9D%2F%ED%81%AC%EA%B8%B0%29%3A+.php


┌──(kali㉿kali)-[~]
└─$ curl -s -o /dev/null -w "%{http_code}\n" http://10.10.10.5/uploads/marker.php
404
```

동일 marker.php 요청 후 /uploads/marker.php 응답 HTTP 404

CASE 02 · 서버 및 DB 최종 검증

재시험 후 파일 미존재와 DB REJECTED 기록을 대조

RED | 파일 시스템

```
logion@LOGION:~$ ls -l /var/www/html/uploads/
total 8
-rw-r--r-- 1 www-data www-data 16 Nov  6 05:27 normal.txt
-rwxrwxrwx 1 www-data www-data 79 Nov  2 05:30 README.txt
```

업로드 폴더에서 marker.php 비존재 확인

RED | MariaDB 업로드 이력

```
logion@mariadb:~$ sudo mysql -e "SELECT document_id,original_filename,mime_type,validation_status FROM logion.uploaded_documents ORDER
 5;"
+-------------+-------------------+--------------------------+-------------------+
| document_id | original_filename | mime_type                | validation_status |
+-------------+-------------------+--------------------------+-------------------+
|           3 | marker.php        | application/octet-stream | REJECTED          |
|           2 | marker.php        | application/octet-stream | ACCEPTED          |
|           1 | normal.txt        | text/plain               | ACCEPTED          |
+-------------+-------------------+--------------------------+-------------------+
```

후속 비허용 업로드 시도 REJECTED · 초기 ACCEPTED 이력과 비교

재시험 결과

기존 PHP 마커의 웹 접근은 404로 확인되었고, 후속 업로드 시도가 DB에서 REJECTED로 기록되었다. 재시험에서 허용 목록과 서버 저장 결과를 비교했다.

CASE 03 · 종료 외주 계정의 접근 시험

partner01 계정과 Bastion 인증 경로를 중심으로 접근 상태 확인

RED | 초기 계정 상태

```
logion@mariadb:~$ sudo mysql -e "SELECT login_id,role,status FROM logion.users WHERE login_id='partner01';"
[sudo] password for logion:
+-----------+-------+--------+
| login_id  | role  | status |
+-----------+-------+--------+
| partner01 | STAFF | ACTIVE |
+-----------+-------+--------+
```

테스트용 partner01 계정 ACTIVE

RED | Bastion 세션·인증 로그

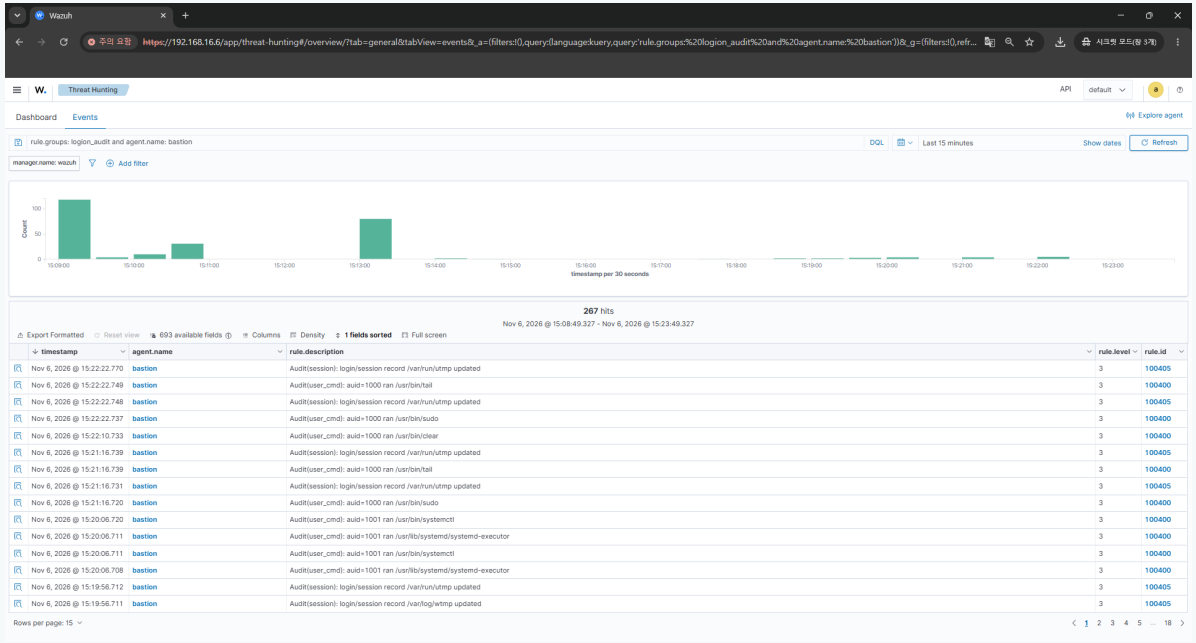
```
logion@bastion:~$ sudo tail -20 /var/log/auth.log
2026-11-06T06:13:04.387257+00:00 bastion sshd[2632]: pam_unix(sshd:session): session opened for user partner01(uid=1001) by partner01(uid=0)
2026-11-06T06:13:04.395615+00:00 bastion systemd-logind[683]: New session 21 of user partner01.
2026-11-06T06:13:04.438255+00:00 bastion (systemd): pam_unix(systemd-user:session): session opened for user partner01(uid=1001) by partner01(uid=0)
2026-11-06T06:14:26.154691+00:00 bastion sudo: partner01 : user NOT in sudoers ; TTY=pts/0 ; PWD=/home/partner01 ; USER=root ; COMMAND=mysql -h 10.10.20.10 -u l
ogion -plogion_dev_pw logion -e 'SELECT login_id,name,phone FROM users;'
2026-11-06T06:15:01.900982+00:00 bastion CRON[2737]: pam_unix(cron:session): session opened for user root(uid=0) by root(uid=0)
2026-11-06T06:15:01.909172+00:00 bastion CRON[2737]: pam_unix(cron:session): session closed for user root
2026-11-06T06:17:01.913363+00:00 bastion CRON[2740]: pam_unix(cron:session): session opened for user root(uid=0) by root(uid=0)
2026-11-06T06:17:01.924432+00:00 bastion CRON[2740]: pam_unix(cron:session): session closed for user root
2026-11-06T06:18:55.594671+00:00 bastion sudo: partner01 : command not allowed ; TTY=pts/0 ; PWD=/home/partner01 ; USER=root ; COMMAND=list
2026-11-06T06:19:52.015177+00:00 bastion sshd[2703]: Received disconnect from 10.10.30.20 port 56060:11: disconnected by user
2026-11-06T06:19:52.015424+00:00 bastion sshd[2703]: Disconnected from user partner01 10.10.30.20 port 56060
2026-11-06T06:19:52.016331+00:00 bastion sshd[2632]: pam_unix(sshd:session): session closed for user partner01
2026-11-06T06:19:52.023991+00:00 bastion systemd-logind[683]: Session 21 logged out. Waiting for processes to exit.
2026-11-06T06:19:52.027567+00:00 bastion systemd-logind[683]: Removed session 21.
2026-11-06T06:20:02.331422+00:00 bastion (sd-pam): pam_unix(systemd-user:session): session closed for user partner01
2026-11-06T06:21:12.901562+00:00 bastion sudo:   logion : TTY=tty1 ; PWD=/home/logion ; USER=root ; COMMAND=/usr/bin/tail -20 /var/log/audit/audit.log
2026-11-06T06:21:12.909717+00:00 bastion sudo: pam_unix(sudo:session): session opened for user root(uid=0) by logion(uid=1000)
2026-11-06T06:21:12.951021+00:00 bastion sudo: pam_unix(sudo:session): session closed for user root
2026-11-06T06:22:17.694395+00:00 bastion sudo:   logion : TTY=tty1 ; PWD=/home/logion ; USER=root ; COMMAND=/usr/bin/tail -20 /var/log/auth.log
2026-11-06T06:22:17.696386+00:00 bastion sudo: pam_unix(sudo:session): session opened for user root(uid=0) by logion(uid=1000)
```

SSH 세션, sudo 권한 실행 및 인증 관련 기록

CASE 03 · Bastion 감사 이벤트 수집

Wazuh에서 명령 실행·세션 감사 흔적을 검색

BLUE | Bastion Audit 이벤트



agent.name=bastion / rule.groups=logion_audit · 100400·100405

관제 결과

Bastion의 사용자 명령 실행 및 세션 관련 감사 이벤트가 Wazuh에 정상적으로 축적되었다. RED의 계정 접근·차단 자료와 함께 계정 활동의 감사 추적 경로를 구성했다.

CASE 03 · 외주 계정 대응 및 재접속 검증

서비스 계정 상태 변경, SSH 잠금, 동일 계정 재시험

서비스 계정 | DISABLED

```
logion@mariadb:~$ sudo mysql -e "UPDATE logion.users SET status='DISABLED' WHERE login_id='partner01';"
logion@mariadb:~$ sudo mysql -e "SELECT login_id,role,status FROM logion.users WHERE login_id='partner01';"
+-----------+-------+----------+
| login_id  | role  | status   |
+-----------+-------+----------+
| partner01 | STAFF | DISABLED |
+-----------+-------+----------+
```

MariaDB users.status에서 partner01 비활성화

서버 계정 | SSH 잠금

```
logion@bastion:~$ sudo passwd -l partner01
passwd: password changed.
```

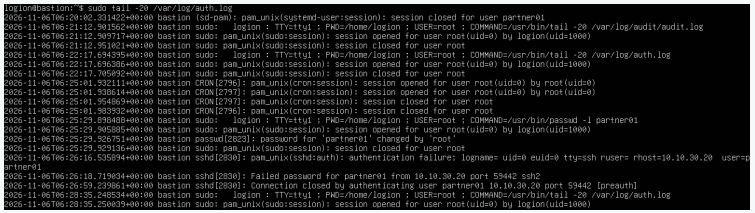
Bastion에서 passwd -l partner01

RED | SSH 재접속

```
test@test:~$ ssh partner01@10.10.20.6
partner01@10.10.20.6's password:
Permission denied, please try again.
```

partner01@10.10.20.6 → Permission denied

RED | Bastion 최종 인증 이력



계정 제어 후 인증 및 세션 로그 확인

종합 결과 · RED 공격과 BLUE 탐지 비교

각 CASE의 실제 관제 이벤트, 서버 조치, 재시험 결과를 한눈에 정리

시나리오	RED 재현 · 결과	BLUE 관제 · 확인	보안 조치 · 재시험
CASE 01 배송지 변경	타인 주문 ID 변경 요청; DB 변경 이력에서 행위자와 주문 소유자 불일치 확인	WAF API 요청 경고 100301 · Level 5 (Host 헤더 CRS 매칭)	서버 소유권 검증 적용; DB api_audit_logs의 403 / DENIED 확인
CASE 02 파일 업로드	PHP 마커 업로드·실행; DB 초기 ACCEPTED 기록	WAF 업로드 관련 경고 100304 · Level 10	비허용 업로드 정책 보완; 재시험 404, DB REJECTED
CASE 03 외주 계정	partner01 계정 활성 상태; Bastion 접근·세션 기록	Bastion Audit 명령·세션 이벤트를 Wazuh에서 확인	계정 DISABLED·SSH 잠금; 재접속 Permission denied

탐지 해석 · CASE 01

BOLA는 HTTP 형식만으로 분류되는 WAF 시그니처 문제가 아니라, 로그인 사용자와 주문 소유자 간 권한을 확인해야 하는 애플리케이션 로직 결함이다.

따라서 WAF는 관련 API 요청 흔적을 제공하고, DB shipment_address_history / api_audit_logs는 비인가 변경과 개선 후 거부를 입증하는 별도 검증 근거로 활용했다.

증빙 출처와 활용 기준

원본 RED·BLUE ZIP의 캡처를 선별해 결과 화면과 짝지어 수록

영역	대표 이미지(원본 ZIP 내 파일명)	사용 목적
토폴로지	GNS3 논리 토폴로지 사용자 제공 이미지	전체 WAN·DMZ·SRV·OFFICE·SOC 설계
사전점검	CAP-01_Wazuh_Agent_Status.png	Wazuh 관제 대상 Agent 상태
CASE 01 / RED	C01-03 BOLA공격.png / C01-04 MariaDB 증거.png / C01-08 DB검증.png	타인 주문 요청·DB 변경·개선 후 거부
CASE 01 / BLUE	C01-01_Wazuh_WAF_Attack_Events.png / C01-02_Wazuh_WAF_Event_Detail_2.png	WAF 이벤트 및 상세 로그
CASE 02 / RED	C02-03 비허용 .php업로드 + 실행.png / C02-08 MariaDB 검증.png	업로드 재현과 재시험
CASE 02 / BLUE	C02-02_Wazuh_WAF_Upload_Events.png	WAF 탐지 100304
CASE 03 / RED	C03-01 잔존 계정 상태.png / C03-05 MariaDB 조치.png / C03-06 Office PC 재시험.png	계정 상태와 SSH 접근 제어
CASE 03 / BLUE	PRE_Bastion_Wazuh_Audit_Log_Check.png	Bastion 감사 이벤트

제출본 안내

보고서는 첨부된 실제 화면을 중심으로 편집했다. 일부 화면의 인증 문자열과 세션 정보는 크롭·마스킹했으며, 기록된 WAF 경고와 DB/SSH 결과를 각각 대응하는 증거로 구분해 서술했다.